

Passive techniques usually are not detected by IDSs, but requires the attacker is in a central location of the network, or can access a specific port and mirror the traffic on the port. It's based on the fact that there are different implementations of the TCP/IP stack. Tools like `siphon` can be used to perform this kind of operation. It could give us information on the OS, software running, etc. As for the countermeasures, they're similar for the ones used for OS detection. One specific is given by moving target defence.

We've seen so far that one key step in the attack is gathering information about the target organisation. How can we make this phase harder? One strategy is to not publish anything (way too exaggerated), the other way is to make very time-consuming the steps of footprinting and scanning. The idea is to use two new technologies: system virtualisation and artificial intelligence. Virtualisation is very efficient, as cloud technology has been improved a lot during last years. The information system will change over time, changing the OS, the version of the application. We can also use AI for our scope, like using an AI-based IDS, detecting in real time what is happening in the system, and modifying it according to a possible attack. We could also create fake services, like honeypots. The attacker will then have to check which service is the real one, and it will take him more time.

Enumeration

It's a more intrusive approach, in the sense of interaction with the target system. Given an identified host that is alive, during this phase we try to find services which are on, and then procede with vulnerability scanning. The traffic is increased by a lot.

The three steps of Footprinting, scanning and enumeration are not performed once, rather the attacker might repeat this multiple times, as he could discover subnets he's never seen before.

What are typical information the attacker wants in this phase? He wants to verify in detail all the information he has accumulated in previous phases, like enumerating user accounts. Even though it may look harmless, it's the basis of the attack. By knowing user list, the attacker might start doing password guessing.

How is this structured? We are going to describe four areas of enumeration:

1. Service fingerprinting: for each active service we need to find what is running there, which version of services.
2. Vulnerability scanners: after knowing which are the services, we look for known vulnerabilities.
3. Basic banner grabbing: used to find out information about services.
4. Enumerating common network services

The enumeration technique depends on the platform we're running it, it differs completely if we're running on a web server, etc.

The typical information that is collected in this phase is given by:

- User account names;
- Misconfigured shared files, which may contain sensitive information;
- Older software versions with known vulnerabilities.

Let's talk about service fingerprinting. The objective is to find the patch level of each service port. We've already determined the node is alive, now we want to realise what is there. This can be done manually, which is a less intrusive approach, as a professional can control how many packets are being sent, but also automatic, which is more difficult to control, but it's a faster approach.

One of the typical tool used is given by `nmap`, which has different functionalities like `nmap-services` (mapping ports to services) and `nmap-service-probe` (given the response, they determine the protocol and the version). Once another tool is given `amap`, used for version scanning. Sometimes, we correlate the result of the first tool with the result of the second one.

Another aspect is vulnerability scanning. There are tools that does this task automatically, like `nessus`, `openvas`. `nessus` is one of the best, as for the database of vulnerabilities. The target hosts are associated with known vulnerabilities.

Countermeasures for the vulnerability scanning is auditing ourselves the scan regularly on the organisation itself to see what is vulnerable. The second one is to use and IDS/IPS, with newer versions of those having rules able to detect vulnerability scanning.

Also `nmap` can do this job. What are the differences? `nmap` is more general, performing different tasks, while `nexus` is specialised in performing vulnerability scanning. `nmap` also has a scripting engine in which we can program. There is also a library of NSE scripts already available.

We've already seeing banner grabbing: interacting with services to obtain information about versions. One of the main tools used is given by `telnet` , which is a manual approach, but we also have an automatised version with `netcat` or `nc` .

By finding vendor and version of software, we check vulnerabilities database and then we can attack.